

The 8-Hour Identity

Just-in-time access for temporary workers without permanent enterprise accounts

Architecture position

Do not confuse a temporary task with a permanent entitlement.

Establish identity when needed, approve access just in time, enforce least privilege, and make authorization disappear automatically.

The trigger A temporary worker needs limited application access for one assignment.	The constraint No corporate directory account and no shift-management platform.	The outcome A bounded, auditable entitlement that expires without manual cleanup.
--	--	--

Sumit Mukherjee

Enterprise Architecture · Cloud Native · Application Modernization · Security
Architecture Point of View · 14 September 2026 · v1.0

Independent professional work · No Red Hat logo used

A successful OTP is not authorization.

Phone OTP proves control of a factor. It does not prove that the person is an approved worker or that today's assignment authorizes today's access.

01 Identity Who is this person? Temporary worker TMP-1042.	02 Authentication Can the person prove control of an accepted factor?	03 Eligibility Is the person part of the approved temporary-worker pool?	04 Entitlement May this person perform this function now?
--	---	--	---

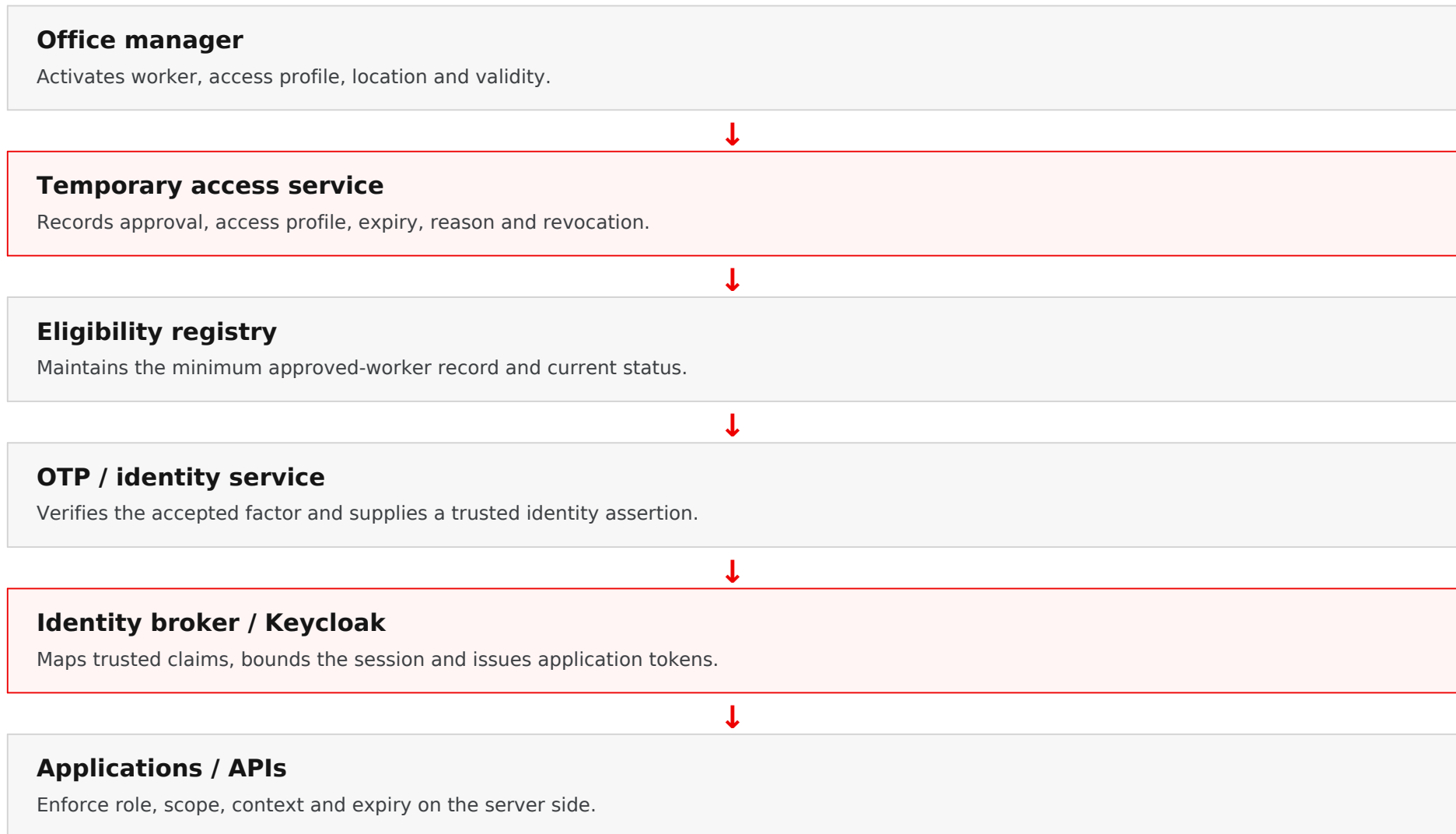
Temporary access decision

Verified phone + approved worker + active entitlement + permitted context = temporary application access

Design implication

Keep business eligibility and time-bound entitlement outside the authentication factor. The identity platform consumes trusted results; it should not infer business authorization merely because authentication succeeded.

Keep the business decision separate from the identity broker.



Architecture boundary

The identity broker is not the worker-scheduling system. Eligibility and today's entitlement are business decisions; the broker turns trusted context into application-facing security.

Create an expiring entitlement - not a permanent employee account.

1 Activate Manager selects an eligible worker and approves Reception until 17:00.	2 Verify Worker enters the registered phone; eligibility and active entitlement are checked.	3 Authenticate OTP or another accepted factor is verified.
4 Broker Trusted claims are mapped into a bounded application identity.	5 Enforce Application/API permits only approved reception functions.	6 Expire Refresh and access stop at expiry or immediate revocation.

Manager activation

Worker: TMP-1042 · Mobile ending 4812
Access profile: Reception Desk
Location: Reception-01
Valid until: Today, 5:00 PM
Reason: Front-desk coverage

The important artifact is an expiring entitlement, not a permanent employee account.

Use trusted context to constrain familiar application permissions.

Trusted context	Derived permission or restriction
access_profile = reception	Allow query creation, lookup and permitted updates
worker_type = temporary	Deny administration and privileged workflows
location = reception-01	Limit access to assigned desk or site where applicable
active_entitlement_id	Require an approved, auditable assignment
valid_until	Reject access beyond the approved window

Authorization model

Attribute-based context feeding a constrained RBAC profile

Only trusted server-side components should supply claims that influence authorization. The browser must never self-declare role, location, approval or expiry.

Expiry must be enforced, not merely displayed.

Session configuration helps, but it is not enough when each worker can have a different assignment end time.

Bound token lifetime Token expiry should never exceed the entitlement's valid-until value.	Stop refresh Deny refresh or token exchange after the entitlement expires.	Re-check when needed Sensitive operations can validate current entitlement at a policy point.
Early revocation A manager can end access before the planned shift end.	Worker blocking Lost phone, worker removal or suspected misuse needs an immediate deny path.	Future eligibility remains Expiry removes current authorization without deleting future eligibility.

Security outcome

The worker may remain known to the organisation while having zero standing access between assignments.

One implementation, not the architecture.

Keycloak can implement the identity-broker role, but the stable architecture roles should survive a product change.

OIDC identity brokering Consume a trusted assertion from the temporary identity service.	Trusted claim mapping Map validated business context into application-facing claims.	Bounded sessions Keep access-token, SSO and client sessions consistent with temporary access.
Client scopes Avoid disclosing unnecessary worker attributes.	No offline access Do not create long-lived offline access for temporary-worker clients.	Transient where compatible Avoid unnecessary persistence when the broker flow and required features support it.

Design principle

Eliminate standing authorization; do not force transience where it weakens supportability.

If a durable identity representation is technically required, keep it minimal and make the entitlement strictly time-bound.

Low friction should not mean low assurance.

Worker verification Register and verify workers before eligibility.	OTP protection Throttle attempts and protect against replay and abuse.	Least privilege Use server-side authorization; UI visibility is not a security boundary.
Audit correlation Record approver, reason, profile, worker, entitlement and application action.	Data minimisation Mask phone numbers and disclose only required claims.	Risk-based step-up Use a managed device, passkey, stronger factor or supervisor confirmation where needed.

Important

SMS OTP is a convenience mechanism, not a universal assurance level.

Authentication strength must match the sensitivity of the data and actions exposed. The reusable pattern is identity + eligibility + entitlement + enforcement, not SMS itself.

Test the controls, not just the login screen.

Recommended baseline Manager activates access on arrival. One deliberate action creates a clear audit record.	Lower-control option Allow the whole eligible pool to authenticate only for lower-risk use with strong contextual restrictions.	Legacy fallback Provision-and-delete only when application constraints require a durable account.
---	---	---

A useful proof should demonstrate

- Activation of TMP-1042 for a bounded Reception profile.
- Successful authentication using a development OTP provider.
- Permitted create, retrieve and update functions.
- 403 Forbidden for administration or bulk export.
- Immediate denial after manager revocation.
- Automatic denial after entitlement expiry.
- Audit correlation across approver, entitlement, worker and application action.
- No unnecessary permanent broker user when transient brokering is used.

Architect's takeaway

Do not ask how quickly you can create and delete a temporary account. Ask whether access can exist only for the task, context and time for which it was approved.

This is an independent architecture Point of View. Product names illustrate possible implementations and do not imply endorsement or representation by any employer or vendor.